

OS Credential Dumping

Sub-techniques (8) 

Adversaries may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password. Credentials can be obtained from OS caches, memory, or structures.^[1] Credentials can then be used to perform [Lateral Movement](#) and access restricted information.

Several of the tools mentioned in associated sub-techniques may be used by both adversaries and professional security testers. Additional custom tools likely exist as well.

ID: T1003

Sub-techniques: [T1003.001](#), [T1003.002](#), [T1003.003](#), [T1003.004](#), [T1003.005](#), [T1003.006](#), [T1003.007](#), [T1003.008](#)

 **Tactic:** [Credential Access](#)

 **Platforms:** Linux, Windows, macOS

Contributors: Ed Williams, Trustwave, SpiderLabs; Tim (Wadhwa-)Brown; Vincent Le Toux; Yves Yonan

Version: 2.2

Created: 31 May 2017

Last Modified: 24 October 2025

[Version Permalink](#)

Procedure Examples

ID	Name	Description
G0007	APT28	APT28 regularly deploys both publicly available (ex: Mimikatz) and custom password retrieval tools on victims. ^{[2][3][4]}
G0050	APT32	APT32 used GetPassword_x64 to harvest credentials. ^{[5][6]}
G0087	APT39	APT39 has used different versions of Mimikatz to obtain credentials. ^[7]
G0001	Axiom	Axiom has been known to dump credentials. ^[8]
G1043	BlackByte	BlackByte used tools such as Cobalt Strike and Mimikatz to dump credentials from victim systems. ^{[9][10]}
S0030	Carbanak	Carbanak obtains Windows logon password details. ^[11]
G1003	Ember Bear	Ember Bear gathers credential material from target systems, such as SSH keys, to facilitate access to victim environments. ^[12]
S0232	HOMEFRY	HOMEFRY can perform credential dumping. ^[13]
G0065	Leviathan	Leviathan has used publicly available tools to dump password hashes, including HOMEFRY . ^[14]
S1146	MgBot	MgBot includes modules for dumping and capturing credentials from process memory. ^[15]
G0129	Mustang_Panda	Mustang_Panda utilized "Hdump" to dump credentials from memory. ^[16]
S0052	OnionDuke	OnionDuke steals credentials from its victims. ^[17]
S0048	PinchDuke	PinchDuke steals credentials from compromised hosts. PinchDuke 's credential stealing functionality is believed to be based on the source code of the Pinch credential stealing malware (also known as LdPinch). Credentials targeted by PinchDuke include ones associated many sources such as Winlnet Credential Cache, and Lightweight Directory Access Protocol (LDAP). ^[17]
G0033	Poseidon Group	Poseidon Group conducts credential dumping on victims, with a focus on obtaining credentials belonging to domain and database servers. ^[18]
S0379	Revenge RAT	Revenge RAT has a plugin for credential harvesting. ^[19]
G0054	Sowbug	Sowbug has used credential dumping tools. ^[20]
G1053	Storm-0501	Storm-0501 has used the SecretsDump module within Impacket can perform credential dumping to obtain account and password information. ^[21]
G0039	Suckfly	Suckfly used a signed credential-dumping tool to obtain victim account credentials. ^[22]
G0131	Tonto Team	Tonto Team has used a variety of credential dumping tools. ^[23]
S0094	Trojan.Karagany	Trojan.Karagany can dump passwords and save them into <code>\ProgramData\Mail\MailAg\pwds.txt</code> . ^[24]

Mitigations

ID	Mitigation	Description
M1015	Active Directory Configuration	Manage the access control list for "Replicating Directory Changes All" and other permissions associated with domain controller replication. ^[25] ^[26] Consider adding users to the "Protected Users" Active Directory security group. This can help limit the caching of users' plaintext credentials. ^[27]
M1040	Behavior Prevention on Endpoint	On Windows 10, enable Attack Surface Reduction (ASR) rules to secure LSASS and prevent credential stealing. ^[28]
M1043	Credential Access Protection	With Windows 10, Microsoft implemented new protections called Credential Guard to protect the LSA secrets that can be used to obtain credentials through forms of credential dumping. It is not configured by default and has hardware and firmware system requirements. ^[29] It also does not protect against all forms of credential dumping. ^[30]
M1041	Encrypt Sensitive Information	Ensure Domain Controller backups are properly secured.
M1028	Operating System Configuration	Consider disabling or restricting NTLM. ^[31] Consider disabling WDigest authentication. ^[32]
M1027	Password Policies	Ensure that local administrator accounts have complex, unique passwords across all systems on the network.
M1026	Privileged Account Management	Windows: Do not put user or admin domain accounts in the local administrator groups across systems unless they are tightly controlled, as this is often equivalent to having a local administrator account with the same password on all systems. Follow best practices for design and administration of an enterprise network to limit privileged account use across administrative tiers. ^[33] Linux: Scraping the passwords from memory requires root privileges. Follow best practices in restricting access to privileged accounts to avoid hostile programs from accessing such sensitive regions of memory.
M1025	Privileged Process Integrity	On Windows 8.1 and Windows Server 2012 R2, enable Protected Process Light for LSA. ^[34]
M1017	User Training	Limit credential overlap across accounts and systems by training users and administrators not to use the same password for multiple accounts.

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0234	Credential Dumping via Sensitive Memory and Registry Access Correlation	AN0648	Processes accessing LSASS memory or SAM registry hives outside of trusted security tools, often followed by file creation or lateral movement. Detects unauthorized access to sensitive OS subsystems for credential extraction.
		AN0649	Processes opening <code>/proc//mem</code> or <code>/proc//maps</code> targeting credential-storing services like sshd or login. Behavior often includes high privilege escalation and memory inspection tools such as gcore or gdb.
		AN0650	Unsigned processes accessing system memory or launching known credential scraping tools (e.g., osascript, dylib injections) to access the Keychain or sensitive memory regions.

References

1. [Tim Wadhwa-Brown. \(2018, November\). Where 2 worlds collide Bringing Mimikatz et al to UNIX. Retrieved October 13, 2021.](#)
2. [ESET. \(2016, October\). En Route with Sednit - Part 2: Observing the Comings and Goings. Retrieved November 21, 2016.](#)
3. [Mueller, R. \(2018, July 13\). Indictment - United States of America vs. VIKTOR BORISOVICH NETYKSHO, et al. Retrieved November 17, 2024.](#)
4. [Brady, S. \(2018, October 3\). Indictment - United States vs Aleksei Sergeyevich Morenets, et al.. Retrieved October 1, 2020.](#)
5. [Dahan, A. \(2017, May 24\). OPERATION COBALT KITTY: A LARGE-SCALE APT IN ASIA CARRIED OUT BY THE OCEANLOTUS GROUP. Retrieved November 5, 2018.](#)
6. [Dahan, A. \(2017\). Operation Cobalt Kitty. Retrieved December 27, 2018.](#)
7. [Rusu, B. \(2020, May 21\). Iranian Chafer APT Targeted Air Transportation and Government in Kuwait and Saudi Arabia. Retrieved May 22, 2020.](#)
8. [Novetta. \(n.d.\). Operation SMN: Axiom Threat Actor Group Report. Retrieved November 12, 2014.](#)
9. [Huseyin Can Yuceel. \(2022, February 21\). TTPs used by BlackByte Ransomware Targeting Critical Infrastructure. Retrieved December 16, 2024.](#)
10. [Microsoft Incident Response. \(2023, July 6\). The five-day job: A BlackByte ransomware intrusion case study. Retrieved December 16, 2024.](#)
11. [Bennett, J., Vengerik, B. \(2017, June 12\). Behind the CARBANAK Backdoor. Retrieved June 11, 2018.](#)
12. [Microsoft Threat Intelligence. \(2023, June 14\). Cadet Blizzard emerges as a novel and distinct Russian threat actor. Retrieved July 10, 2023.](#)
13. [FireEye. \(2018, March 16\). Suspected Chinese Cyber Espionage Group \(TEMP.Periscope\) Targeting U.S. Engineering and Maritime Industries. Retrieved April 11, 2018.](#)
14. [Plan, F., et al. \(2019, March 4\). APT40: Examining a China-Nexus Espionage Actor. Retrieved March 18, 2019.](#)
15. [Threat Hunter Team. \(2023, April 20\). Daggerfly: APT Actor Targets Telecoms Company in Africa. Retrieved July 25, 2024.](#)
16. [Lior Rochberger, Tom Fakterman, Robert Falcone. \(2023, September 22\). Cyberespionage Attacks Against Southeast Asian Government Linked to Statel Taurus, Aka Mustang Panda. Retrieved September 9, 2025.](#)
17. [F-Secure Labs. \(2015, September 17\). The Dukes: 7 years of Russian cyberespionage. Retrieved December 10, 2015.](#)
18. [Kaspersky Lab's Global Research and Analysis Team. \(2016, February 9\). Poseidon Group: a Targeted Attack Boutique specializing in global cyber-espionage. Retrieved March 16, 2016.](#)
19. [Livelli, K, et al. \(2018, November 12\). Operation Shaheen. Retrieved May 1, 2019.](#)
20. [Symantec Security Response. \(2017, November 7\). Sowbug: Cyber espionage group targets South American and Southeast Asian governments. Retrieved November 16, 2017.](#)
21. [Microsoft Threat Intelligence. \(2024, September 26\). Storm-0501: Ransomware attacks expanding to hybrid cloud environments. Retrieved October 19, 2025.](#)
22. [DiMaggio, J. \(2016, May 17\). Indian organizations targeted in Suckfly attacks. Retrieved August 3, 2016.](#)
23. [Daniel Lugh, Jaromir Horejsi. \(2020, October 2\). Tonto Team - Exploring the TTPs of an advanced threat actor operating a large infrastructure. Retrieved October 17, 2021.](#)
24. [Symantec Security Response. \(2014, June 30\). Dragonfly: Cyberespionage Attacks Against Energy Suppliers. Retrieved April 8, 2016.](#)
25. [Metcalf, S. \(2015, September 25\). Mimikatz DCSync Usage, Exploitation, and Detection. Retrieved December 4, 2017.](#)
26. [Microsoft. \(n.d.\). How to grant the "Replicating Directory Changes" permission for the Microsoft Metadirectory Services ADMA service account. Retrieved December 4, 2017.](#)
27. [Microsoft. \(2016, October 12\). Protected Users Security Group. Retrieved May 29, 2020.](#)
28. [Microsoft. \(2021, July 2\). Use attack surface reduction rules to prevent malware infection. Retrieved June 24, 2021.](#)
29. [Lich, B. \(2016, May 31\). Protect derived domain credentials with Credential Guard. Retrieved June 1, 2016.](#)
30. [NSA IAD. \(2017, April 20\). Secure Host Baseline - Credential Guard. Retrieved April 25, 2017.](#)
31. [Microsoft. \(2012, November 29\). Using security policies to restrict NTLM traffic. Retrieved December 4, 2017.](#)
32. [Microsoft. \(2014, May 13\). Microsoft Security Advisory: Update to improve credentials protection and management. Retrieved June 8, 2020.](#)
33. [Plett, C., Poggemeyer, L. \(12, October 26\). Securing Privileged Access Reference Material. Retrieved April 25, 2017.](#)
34. [Microsoft. \(2013, July 31\). Configuring Additional LSA Protection. Retrieved February 13, 2015.](#)